Basic SSRF Against Another Back-end System

Lab Overview

- **Platform:** PortSwigger Web Security Academy
- **Vulnerability:** Server-Side Request Forgery (SSRF)
- **Difficulty:** Apprentice

Description

SSRF is a vulnerability that allows an attacker to manipulate server-side requests to access unintended resources. In this lab, the vulnerable application can be manipulated to send requests to another internal back-end system.

Exploitation Steps

1. Browse the lab and identify the feature that fetches a resource using a URL.
2. Intercept the HTTP request using Burp Suite.
3. Send the request to Burp Repeater.
4. Modify the URL parameter to target the internal back-end system specified in the lab.
5. Analyze the response and complete the lab objective.

Impact

- Unauthorized access to internal services.
- Exposure of sensitive information.
- Potential access to restricted administrative interfaces.

Remediation

- Validate user-controlled URLs.
- Allow requests only to trusted destinations.
- Block unauthorized internal IP addresses and ports.
- Restrict outbound network connections from application servers.

Conclusion

This lab demonstrates how improper URL validation can allow SSRF attacks against internal systems. Strong destination validation and network restrictions help reduce this risk.

Reference: PortSwigger Web Security Academy — SSRF